

한전KPS(주) 상임감사

시 정 요 구

일련번호 2024-☆☆☆☆처-004

제 목 “시스템 접근제어 솔루션” 계정 및 권한 관리 미흡

관계부서 ☆☆☆☆처

조치부서 ☆☆☆☆처

내 용

1. 업무개요

회사는 「국가 정보보안 기본지침」 및 「산업통상자원부 정보보안 세부지침」에 따라 정보보안 업무를 수행하고 있다. 또한, 회사의 주요정보 및 직무 관련된 정보의 외부 유출 가능성을 차단하기 위하여 「정보보안 업무처리 기준」을 수립하고, 시스템 접근제어 솔루션(NGS)¹⁾을 도입하여 [그림]과 같이 내·외부 사용자의 정보보안·정보시스템·네트워크설비에 대한 접근을 제어하고 접속·작업 이력을 관리감독 및 통제하고 있다.

[그림] 시스템 접근제어 솔루션 접속 흐름도



2. 판단기준

「정보보안 업무처리기준」 제75조(계정 관리) 제3항에 따라 정보시스템 관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생한 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하여야 하며, 「회사정보보호규정」 제29조(전산시스템 보안관리) 제2항에 따라 주관

1) 내·외부 사용자의 정보보안·정보시스템·네트워크설비에 대한 접근제어 및 접속/작업이력 관리·감독 및 통제하는 시스템

부서는 반기에 한 번씩 권한승인내역에 대해 조사하고 재조정하여야 한다.

따라서, ☆☆☆☆처(★★★★부)는 회사의 주요 정보가 유출되지 않도록 정보통신망 또는 정보시스템의 접속에 필요한 사용자 계정을 만들고자 할 경우 사용자에게 대한 신상을 면밀히 검토 후 부여하여야 하고 사용자의 신분상 변동사항이 발생한 즉시 사용자 계정을 회수하여 접속을 통제하여야 한다. 또한 운영 중 발생하는 인적 실수를 예방하기 위하여, 사용자 계정에 대해서 반기에 한 번씩 조사를 진행하여 사용자 계정 운영 현황을 파악하고 불필요한 계정 및 권한을 회수하여야 한다.

3. 감사결과 확인된 문제점

그런데 ☆☆☆☆처(★★★★부)는 2024. 10. 31. 기준으로 [표 1]과 같이 시스템 접근제어 솔루션의 총 11개의 사용자 계정(업무망 8개, 인터넷망 3개)에 대해 면밀히 검토하지 않고 종료일을 무제한으로 설정하거나, 권한이 없는 계정을 운영하는 등 검토가 미흡한 계정을 운영하고 있었다. 또한, [표 2]와 같이 직원 3명(업무망 2명, 인터넷망 1명)에 대해서도 인사이동 및 업무분장 등으로 사용자의 신분상 변동이 발생하였음에도 사용자 권한에 대한 회수가 이루어지지 않은 것으로 확인되었다.

[표 1] 시스템 접근제어 솔루션 사용자 계정 기간 미설정 내역

구분		사번	이름	시작일	종료일	비고
계정	업무망	♠♠♠065♠	♠♠♠	'22.05.25.	무제한	종료일 미설정
		♡♡♡002♡	♡♡♡	'21.06.30.	무제한	종료일 미설정
		♥♥♥016♥	♥♥♥	'22.06.29.	무제한	종료일 미설정
		♣♣♣002♣	♣♣♣	'23.04.19.	무제한	종료일 미설정
		♣♣♣027♣	♣♣♣	'23.12.20.	무제한	종료일 미설정
		◎◎◎009◎	◎◎◎	'23.07.03.	무제한	종료일 미설정 인사이동(♡♥♡→♣♣♣센터) ('24.01.31.)
		◆◆◆000◆	◆◆◆	'20.02.18.	무제한	종료일 미설정 권한이 없는 계정
		▣▣▣017▣	▣▣▣	'24.05.08.	'25.05.07.	권한이 없는 계정
	인터넷망	♣♣♣027♣	♣♣♣	'23.12.20.	무제한	종료일 미설정
		●●●042●	●●●●	'20.10.19.	무제한	종료일 미설정
		◆◆◆000◆	◆◆◆	'20.02.18.	무제한	종료일 미설정
					권한이 없는 계정	

[표 2] 시스템 접근제어 솔루션 접속가능 사용자 권한 미회수 내역

구분		사번	이름	접근가능 시스템	비고
권한	업무망	♣♣♣009♣	○○○	교육훈련체계(SAT)	인사이동(♥♥♥→♣♣♣센터) (‘24.01.31.)
		♣♣♣019♣	●●●	전사포탈 등 187개	업무분장(서버담당자→기획) (‘24.02.13.)
	인터넷망	♣♣♣019♣	●●●	인터넷메일 등 87개	

따라서, ☆☆☆☆처(★★★★부)는 회사에 주요 정보가 유출되지 않도록 시스템 접근제어 솔루션 사용자 계정을 부여하고자 할 경우 명확하게 기간을 설정하여 정보통신망 또는 정보시스템의 접근을 통제할 필요가 있으며, 계정 및 권한 미회수를 방지하기 위하여 「회사정보보호규정」에 따라 반기에 한번 씩 권한승인내역에 대해 조사하고 재조정할 필요가 있다.

관계부서 의견

☆☆☆☆처는 시스템 접근제어 솔루션 사용자 계정에 대한 관리를 소홀히 한 사실을 인정하고, 추후 같은 상황이 발생하지 않도록 업무에 만전을 기할 것을 의견으로 제시하였다.

조치할 사항 ☆☆☆☆처장은

- ① 시스템 접근제어 솔루션의 계정 및 접근권한을 재검토 및 변경하고, (시정)
- ② 「회사정보보호규정」 제29조에 따라 반기에 한 번씩 권한승인내역에 대해 조사하고 재조정하시기 바랍니다. (시정)